

DFIR Comparison Report: CORP-112-309

DFIR Comparison Report — Host CORP-112-309

Analysis type: Two-package MDE live-response differential (pre vs. post) Host: CORP-112-309 (Windows 11 Pro) Report date: 2026-08-13

1. Baseline determination

Both packages are identical-structure Microsoft Defender for Endpoint (MDE) live-response collections from the same host. Collection metadata in `Forensics_Collection_Summary.csv` establishes order:

Package	Collection time (UTC)	Role
Pre_Breach_MDE_Investigation_Package.zip	2026-08-13 00:09:30	Baseline
Post_Breach_MDE_Investigation_Package.zip	2026-08-13 21:37:26	Comparison (~21.5 h later)

The earliest capture is treated as the baseline. Filenames are consistent with the embedded timestamps.

Important caveat on baseline purity: per the build sequence for this exercise, the pre-breach package was captured *after* the local `administrator/guest` bait accounts and the bait MySQL account had already been created, but *before* the Windows Firewall was disabled and the NSG opened. This is not a clean pre-modification baseline — it is a snapshot immediately before public exposure. The Users/Groups deltas below reflect that: bait accounts are already present in both packages, and the meaningful boundary this report tests is exposure → compromise, not account-creation → compromise.

2. Summary verdict

Compromise indicators found: YES (confirmed, not merely attempted). Confidence: HIGH that the attack occurred; HIGH that it succeeded on at least two fronts (MySQL data destruction, one Windows RDP logon).

A large-scale external MySQL credential brute-force hit the host during the window, immediately following the Windows Firewall being disabled on all profiles and the NSG being opened to allow-all-inbound. Unlike a typical “attempted but not confirmed successful” case, this incident includes a confirmed successful MySQL compromise (schema destruction and ransom note) and a confirmed successful Windows RDP logon to the bait `administrator` account — though the latter shows no evidence of hands-on-keyboard follow-through.

3. Table of notable deltas

Category	Item	Change	Benign / Suspicious	Evidence
Firewall	EnableFirewall — Domain/Standard/Public (live <code>Parameters\FirewallPolicy</code> key)	CHANGED 0x1 → 0x0	Suspicious (deliberate, per build record)	post/Autoruns/Autoruns.txt — <code>SharedAccess\Parameters\FirewallPolicy*Profile</code>
Network	4 established inbound TCP/3389 sessions (59.15.116.99, 80.94.95.83 ×2, 120.238.101.112)	ADDED	Suspicious	post/NetworkConnections/ActiveNetConnections.txt
Network	MySQL TCP/3306 and TCP/33060 listening on 0.0.0.0	UNCHANGED (present in both)	Expected (bait service, by design)	pre & post/NetworkConnections/ActiveNetConnections.txt
Users and Groups	<code>administrator</code> , <code>johnjames</code> in Administrators group	UNCHANGED	Benign (<code>johnjames</code> is the analyst’s legitimate account; <code>administrator</code> is the intentional bait account, already present pre-exposure)	pre & post/Users and Groups/LocalGroups.txt
Users and Groups	<code>administrator</code> , <code>Guest</code> in Users group	UNCHANGED	Expected (bait accounts, by design, present in both packages)	pre & post/Users and Groups/LocalGroups.txt
Users and Groups	Active interactive session	CHANGED — pre: <code>johnjames</code> active RDP session; post: no active session (No User exists	Benign (analyst’s own session ended prior to post-capture)	pre & post/Users and Groups/QueryUser.txt

		for *)		
Scheduled Tasks	\Microsoft\Windows\Setup\SetupCleanupTask	REMOVED	Benign (routine post-setup cleanup, expected on a several-day-old VM)	pre/post ScheduledTasks.csv
Scheduled Tasks	All other tasks (301 of 302)	UNCHANGED	Benign	pre/post ScheduledTasks.csv
Processes	Interactive-session processes (explorer.exe, msedge.exe, msedgewebview2.exe, MySQLWorkbench.exe, WindowsTerminal.exe, OneDrive.exe, and related shell components)	REMOVED (present in pre, absent in post)	Benign — reflects the analyst's own interactive session ending before the post-capture, not attacker cleanup	pre/post Processes/Processes.csv
Processes	Any new/unrecognized executable	—	None found	pre/post Processes/Processes.csv
Autoruns	Persistence entries referencing AppData\Roaming, Users\Public, or similar non-standard executable paths	UNCHANGED	Benign — no new entries in either direction	pre/post Autoruns/Autoruns.txt
Installed Programs	—	UNCHANGED	Benign	InstalledPrograms.csv

4. Strongest compromise indicators (prioritized, ATT&CK-mapped)

1. **Firewall disabled, all profiles (0x1 → 0x0)** — Defense Evasion, T1562.004 (Disable or Modify System Firewall). Pivotal change; combined with the NSG being opened, it exposed MySQL (3306) and RDP (3389) to the internet and enabled everything below. Per the build record, this was a deliberate exposure step, not a stealthy attacker action — but it is functionally identical to the technique regardless of who executed it.
2. **MySQL brute-force from 13 distinct external IPs (104 authentication events, 45 failures / 59 successes)** — Credential Access, T1110 (Brute Force). Dominant activity clustered in two destructive sessions; full detail in the companion incident report's Timeline and IOC sections.
3. **Successful RDP logon to the bait administrator account from 59.15.116.99** — Initial Access / Valid Accounts, T1078. Confirmed via DeviceLogonEvents, corroborated by both the standing Sentinel rule and an ad hoc hunt.
4. **Full schema destruction and ransom-note insertion following successful MySQL authentication** — Impact, T1485 (Data Destruction), plus an extortion/financial-impact component not cleanly mapped to a single core ATT&CK technique.

Exculpatory / scope-limiting observations

- The successful administrator RDP logon was **not** followed by any process activity attributed to that account in the following six hours (DeviceProcessEvents, zero rows) — no evidence of hands-on-keyboard activity, file staging, or persistence mechanisms tied to that session.
- No new or unrecognized executables appear in the post-package Processes.csv or Autoruns.txt relative to baseline.
- Local group membership (Administrators, Guests, Users) is unchanged between packages — no privilege escalation via new group membership occurred during the window.
- Installed Programs list is unchanged — no software was installed by an attacker.
- NTANetAnalytics shows only benign denied outbound NTP traffic from the host itself in this window — no attacker-attributable outbound C2/exfiltration flows.

5. Probable incident type

Opportunistic, internet-scanning-driven credential attack against an intentionally exposed honeypot, immediately enabled by a deliberate firewall/NSG exposure step. On the MySQL side, this escalated to a confirmed compromise: full data destruction and a Bitcoin ransom-note extortion attempt, consistent with automated “wipe-and-ransom” campaigns documented in threat intelligence (see the companion incident report's MITRE ATT&CK Mapping section). On the Windows side, a separate successful RDP authentication to the bait account occurred, but without observable follow-on interactive activity — consistent with an automated credential-validation tool rather than a human operator taking further action inside the session.

This is not ransomware in the traditional encrypting sense — the MySQL data was deleted and held for ransom via a note, not encrypted in place — and there is no evidence of lateral movement, new persistence mechanisms, or privilege escalation beyond the intentionally provisioned bait accounts.

6. Indicators of Compromise (IOCs)

MySQL brute-force source IPs (13 distinct, full breakdown with per-IP event counts in the companion incident report's IOC table): 77.90.185.30, 64.89.163.165, 77.90.185.21, 64.89.163.94, 64.89.163.141, 64.89.163.154, 64.89.163.139, 213.209.159.115, 194.32.120.197, 35.195.204.188, 103.234.99.115, 64.89.163.146, 35.190.210.118, 64.89.163.148

RDP source IPs (established TCP/3389 sessions observed at post-capture time): 59.15.116.99 (confirmed successful `administrator` authentication via `DeviceLogonEvents`); 80.94.95.83 and 120.238.101.112 (established connections present in the post-package network snapshot; authentication outcome for these two was not independently cross-verified against `DeviceLogonEvents` and should be treated as unconfirmed)

Ransom/extortion artifacts: BTC address `bc1q7jps5432akuf1g9flw2vu6hgmmj5hrrdu6c5gm`; contact email `ak+27i5n@onionmail.org`; reference URL `hxxps://bit[.]ly/22mysql`; DATAID `27I5N`; secondary contact Telegram handle `@akilahelp` via `hxxps://bit[.]ly/telegram423`

Targeted MySQL accounts: `root`, `sa`, `admin`

7. Gaps and limitations

- The Security Event Log (`security.evtx`) was collected in both packages but was not parsed as part of this differential — findings above rely on `DeviceLogonEvents/DeviceProcessEvents` (Defender Advanced Hunting) rather than raw Security log event IDs. A follow-up pass extracting EID 4624/4625/4740 directly from the `.evtx` files would allow direct cross-validation against the KQL-derived findings and would more precisely disambiguate logon types (Type 3 network vs. Type 10 RDP) the way the Security log natively records them.
- Local firewall connection logging (`pfirewall.log`) was unavailable in both packages — the firewall was disabled before/without logging having been separately enabled, so this normally free evidence source could not corroborate connection-level detail beyond what Defender/network telemetry already captured.
- The origin of the firewall-disable action is known from the build record (a deliberate, recorded step) rather than independently reconstructed from host telemetry alone — in a real (non-lab) investigation, this would need to be established via 4657/4670-class registry-audit events or endpoint command-line logging, neither of which was enabled here.
- Process-creation command-line auditing was not confirmed enabled; `Processes.csv` in both packages provides process name/path but full command-line reconstruction relies on the separately-collected `DeviceProcessEvents` KQL export rather than this comparison alone.
- The two RDP source IPs seen only in the post-package network snapshot (80.94.95.83, 120.238.101.112) were not cross-referenced against `DeviceLogonEvents` to confirm whether authentication succeeded, failed, or was still in progress at capture time.

8. Recommended immediate actions

1. Re-enable the Windows Firewall on all profiles and confirm via policy/configuration management going forward.
2. Restrict TCP/3389 and TCP/3306 at the network perimeter for any future iteration of this exercise; these should not remain internet-reachable indefinitely.
3. Rotate or remove all bait credentials (`administrator`, `guest`, `root@'%'`) — already completed as part of eradication in the companion incident report.
4. Cross-reference the two unconfirmed RDP source IPs against `DeviceLogonEvents` to close the open gap noted in Section 7.
5. Block the listed MySQL brute-force IOC IPs and the RDP source IPs at the network layer if this host or environment persists beyond the current exercise.
6. For any future run of this exercise, parse the Security Event Log directly (in addition to Advanced Hunting tables) to build a fully self-contained differential that doesn't depend on a separate telemetry pipeline.